LockonDocs - Production Readiness Plan

Overview

Field	Value
Document	Production Readiness Plan
Owner	Developer (Eazi-Business, UK)
Client	Tracey, YoWAD Tech (USA)
Status	Phases 1 and 2 complete; client architecture phases A, B and C built (Builds 25 to 31); awaiting manual deploy
Data sensitivity	High (PII, medical, school records)
Target infra	US-based (storage + compute)

This document tracks the work required to take LockonDocs from the accepted Phase 1 proof of concept to a full production release for a US client. It is a living document: update it as items are completed, and keep the build log in `build_state.md` in step.

Where the app stands today (end of Phase 1)

The Phase 1 build is a solid, secure foundation:

- **Authentication:** email and password, bcrypt-hashed passwords, JWT sessions via the auth layer.
- **Per-user isolation:** every data route (documents, folders, presigned upload) reads the user from the session, rejects unauthenticated calls with 401, and re-verifies folder ownership before attaching a document. No cross-user access path was found.
- **Storage:** documents are stored privately in S3 and served only through short-lived signed URLs (1 hour). SVG inline rendering is blocked (script-injection defense) and filenames are sanitized.
- **Data model:** users, folders, documents with soft-delete on the user, storage tracking, and sensible indexes.
- **GoodBarber embed:** the app loads in the embed, and the landing screen's "Access My Vault" breaks out to a top-level browser context so login cookies work first-party. Confirmed working by the client.

Encryption at rest

Server-side encryption at rest is active. Application-level (envelope) encryption remains deferred. To keep the record precise, there are two distinct layers here and only the first is in place:

- **Server-side encryption (SSE-S3, AES-256): active and verified.** As of Build 29 the app explicitly requests SSE-S3 (AES-256) on every uploaded object (the upload presign sets `ServerSideEn-`

`cryption: AES256` and the client sends the matching header), so encryption is actively required by the app rather than relying on the bucket default alone. This was verified: an object stored without the encryption header is rejected (403), and an object stored with it succeeds and is encrypted. This protects data at rest on the storage platform (for example if the underlying disks were compromised).

- **Application-level (envelope) encryption: still deferred (accepted risk).** The app does not encrypt document contents with its own keys before upload, and does not use SSE-KMS customer-managed keys. This means an infrastructure operator with storage access could in principle read documents. The client chose not to fund this work item at this stage.
- Because the production bucket is a shared managed bucket, its account-level default-encryption and public-access settings cannot be read or changed by the app. The app-enforced SSE-S3 header is what guarantees each LockonDocs object is encrypted regardless of the bucket default.
- Do not claim in the UI or to end users that documents are encrypted with customer-managed or end-to-end keys. Server-side encryption at rest (AES-256) may be stated accurately; application-level encryption is not yet built.
- If Tracey later wants stronger guarantees (auditable customer-managed keys, or documents unreadable even to an infrastructure operator), this can be revisited as a costed change. It is deferred, not forgotten.

Access security (auto-lock, masked fields, re-authentication)

Added in Build 31 as the Phase C security bundle. These are access controls on the running app, not encryption; they reduce the risk of an unlocked or left-open phone exposing documents inside the GoodBarber shell.

- **Auto-lock.** The vault locks after a period of inactivity, and also locks on return if the app has been left in the background for at least that same period (changed in Build 34: it previously locked on any return from the background, however brief). The timeout is a per-user setting (1, 3, 5 or 10 minutes, or Never) defaulting to 5 minutes. The lock is a password overlay, not a sign-out, so the first-party session and cookies survive and unlocking is a single password step. The locked state is persisted on the device so a reload keeps the vault locked, and it is cleared whenever there is no signed-in user so a fresh sign-in never lands on the lock screen.
- **Masked sensitive fields.** On a document’s Details panel, sensitive values (ID, passport, license, VIN, account, policy, username, patient name and similar) are masked by default and revealed only after a password step, and are re-masked automatically when the app is backgrounded. Only text and number fields whose names match a sensitive pattern are masked; ordinary descriptive fields stay visible.
- **Re-authentication.** A dedicated endpoint re-checks the signed-in user’s password for the unlock and reveal steps. It does not touch the login lockout counters (it confirms an already-authenticated user) and it records an audit entry for each success or failure.
- Not included in this bundle and still open: document sharing, multi-person profiles, and application-level (envelope) encryption at rest (the last remains a deferred accepted risk, above). Sharing and offline access are reviewed in `sharing_offline_review.md` (Build 40).

Phase 2 - Full Feature Build

Status: complete (Build 11). All items below are built. The unticked boxes are retained as the original plan of record.

Agreed price: £2,000 (~$2,540 USD). Scope below combines the proposal's Phase 2 features with the production hardening agreed in planning (encryption-at-rest excluded per client decision).

Functional features

- [ ] Folder rename
- [ ] Move documents between folders
- [ ] Document search (by name)
- [ ] Document sorting (by date, by name)
- [ ] Admin panel driven by the existing `isAdmin` flag (user list, storage overview, basic controls)
- [ ] Enhanced image processing: crop, rotate, multi-page capture, PDF export
- [ ] Custom folder icons (graphics to be supplied by Tracey - blocked on assets)

Production hardening (folded into Phase 2)

- [ ] Password policy (minimum strength enforced on signup and change)
- [ ] Password reset flow (email a time-limited reset link)
- [ ] Email verification (optional, on by default for new signups)
- [ ] Login rate limiting + temporary lockout after repeated failures
- [ ] Server-side enforcement of upload file type and size
- [ ] Server-side enforcement of per-user storage quota
- [ ] Audit log of key actions (login, document view, delete, account deletion)
- [ ] Two-factor authentication (optional, deferred unless Tracey requests it - noted for scope)

Privacy and consumer rights (US)

- [ ] "Download my data" export (documents + metadata)
- [ ] Genuine "delete my account and all documents" flow (purges S3 objects + DB records)

Phase 3 - GoodBarber Production Integration

Agreed price: £500 (~$635 USD).

- [ ] Confirm session behavior on the new production URL
- [ ] Decide whether GoodBarber auth pass-through is wanted (if GoodBarber issues tokens)
- [ ] Cross-origin and cookie behavior pass on real iOS and Android devices
- [ ] Confirm camera and scanning work through the production embed on real devices

Phase 4 - Launch Prep (Optional)

Agreed price: £300 (~$380 USD).

- [ ] Performance optimization pass
- [ ] Final security review
- [ ] User acceptance testing with Tracey
- [ ] Production go-live

Security and compliance considerations (US client)

These are considerations for the developer and Tracey to confirm. They are not legal advice; where a legal question is flagged, get it confirmed rather than assumed.

Authentication hardening

- Rate limiting and lockout on login and signup to slow brute-force attempts.
- Password reset and a sensible password policy.
- Optional two-factor authentication given the data sensitivity.
- Session cookies confirmed secure and correctly scoped on the production domain.

Access and abuse controls

- Server-side validation of upload content type and size (do not trust the client).
- Enforcement of the per-user storage quota (built in Phase 2: uploads are checked against the remaining quota and rejected when the limit would be exceeded).
- Audit log of sensitive actions for security and any later compliance request.

US regulatory considerations

- **Data residency:** keep storage and compute in US regions. Verify the production S3 region and database region are both US.
- **CCPA / CPRA (California):** consumers have rights to access and delete their personal data. A data export and a real account+documents deletion flow cover most of this and are good practice regardless of state.
- **Breach notification:** all US states have breach-notification laws. An audit log and a documented incident process help here.
- **COPPA:** the app can hold children's school records. If under-13s use it, or parents store children's data, COPPA may apply. Confirm with Tracey.
- **HIPAA:** most likely does not apply, because HIPAA governs healthcare providers and their business associates, not individuals storing their own medical documents in a personal vault. Because a "Medical" folder is prominent, get this confirmed rather than assumed.
- **Policy documents:** a short written data-handling and retention policy will help with app-store review and user trust.

Domain migration (Build 20, 2026-08-23)

- The service was migrated to the new primary host **vault.lockondocs.app** (domain verified and deployed by the developer). The application code carries no hard-coded host names: the email sender address, page metadata and absolute links all derive at runtime from the deployment URL, which is set automatically per environment, so migration needs only a deploy to the new host.
- Decision (2026-08-31): the previous hosts (securevault.dowmandigitalservices.com and lockondocs.abacusai.app) have been retired. vault.lockondocs.app is the single live host and the only target for a deploy.

Automated backups (Build 20)

- **Weekly code backup to GitHub:** a scheduled job pushes the application source to RichardDowman/lockondocs (main). It uses a dedicated working clone, never touches the managed project's own version control, and excludes dependencies, build output and all secret and environment files, so no credentials are committed.
- **Daily storage verification:** a scheduled job reads the database read-only to confirm document count, total bytes and distinct users, and records the snapshot. It performs only reads plus a single status write, so it cannot alter or delete documents. This is a verification and inventory snapshot, not a physical second copy. A true second-copy backup would need a separate destination bucket

and would add storage cost; it was intentionally deferred pending a developer decision (see open decisions).
- Both jobs record their result to the `BackupLog` table (via the `/api/backups/ingest` endpoint), and the admin Backups screen surfaces the latest status and history.

Production cutover checklist

When the new production URL and delegate access are available:

- [x] Point the app at the new production domain (vault.lockondocs.app, Build 20)
- [ ] Provision production database in a US region
- [ ] Provision production S3 bucket in a US region, with default encryption + block-public-access confirmed
- [ ] Move all secrets into the production environment (never in client-side code or the repo)
- [ ] Run the schema migration against the production database
- [ ] Verify default-folder creation for new users
- [ ] Verify signed-URL generation against the production bucket
- [ ] Configure the custom-domain email sender for password reset / notifications once the domain is live
- [ ] Full end-to-end test inside the GoodBarber app on real iOS and Android devices
- [ ] Confirm login, scan, save, view, search, and delete all work in the production embed

Open decisions (need input)

- **Two-factor authentication:** in or out for launch?
- **Email verification:** required before first login, or soft (allow login, nudge to verify)?
- **COPPA / HIPAA applicability:** confirm with Tracey given the data types.
- **Custom folder icons:** awaiting graphics from Tracey.
- **True second-copy storage backup:** the daily job currently verifies durable storage rather than copying to a second bucket. Decide whether a physical second-copy backup (separate destination bucket, added storage cost) is wanted before wider launch.

Last updated: 2026-08-31 (Build 31 review). Keep this in step with `build_state.md`.